



DIGITAL TRUST FUTURES
FOUNDATION

DIGITAL SOVEREIGNTY IN PRACTICE

Cyberwar Makes Sovereignty Non-Negotiable

Digital Public Infrastructure in an active threat environment

Digital Sovereignty Series | Article 3 of 6

Why this matters now

Digital Public Infrastructure carries essential public services through a persistent digital threat environment. AI-enabled attacks, compromised software supply chains and cross-border dependencies make sovereignty a question of proven control and citizen protection. This article examines what that means for DPI design, funding and independent safeguards.

Prepared by Godfrey Kutumela, Digital Trust Futures Foundation

September 2026 | Series version 1.0 | Classification: Public

Contents

Executive summary	3
1. Cyberwar is persistent, not episodic	3
2. AI has become the attacker force multiplier	4
3. DPI is now critical national infrastructure	5
4. Attrition and the Global South exposure gap	6
Series bridge	7
About the author	7
About Digital Trust Futures Foundation	8
References and further reading	8

Executive summary

Cyberwar changes the digital sovereignty debate by removing the comfortable assumption that national digital systems operate in a mostly peaceful environment interrupted by occasional incidents. For identity, payments, health, welfare and data exchange platforms, threat activity is now continuous, adaptive, and often designed to remain invisible until it achieves strategic advantage.

This article argues that sovereignty is non-negotiable because DPI is now part of the attack surface of the state. AI accelerates adversaries, critical infrastructure is a deliberate target, and the countries moving fastest into population-scale digital dependency are often the countries with the least dedicated security capacity.

The Foundation approaches this as a public-interest protection problem: infrastructure must remain secure, people must remain safe, rights must remain enforceable, and failures must be independently visible. A country cannot rely on vendor assurances or the absence of outages as proof that its identity, payment and welfare systems will remain usable under deliberate pressure. Sovereignty needs evidence: clear authority, rehearsed continuity, defensible data access and practical avenues for citizens to challenge harm.

Key points for policymakers and DPI leaders

- Operational stability is not proof of security: seek evidence of detection, containment and recovery.
- AI changes both sides of the risk: faster attacks and new failure paths inside AI-enabled DPI decisions.
- Treat identity, payments and data exchange as essential public services, with protected security budgets.
- Close the defence gap through domestic capability, regional cooperation and independent assurance.

1. Cyberwar is persistent, not episodic

Conventional digital policy often assumes that systems operate normally until an incident occurs. Modern cyber conflict challenges that assumption. Adversaries may be present, mapping dependencies, testing credentials, probing APIs, poisoning supply chains, or waiting inside networks long before a public disruption is visible.

This matters for sovereignty because a country may appear operationally stable while its strategic digital foundations are being quietly degraded. The absence of a visible outage does not prove that a system is secure, sovereign, or under effective national control.

For a DPI operator, this changes the meaning of “normal operations”. A successful identity check or payment transaction says little about whether an attacker has gained privileged access, captured a service account, or mapped the dependencies they will target later. An adversary can use a quiet period to learn how payment settlement, identity verification, beneficiary enrolment and incident escalation actually work.

A sovereignty assessment should therefore examine who can see and stop malicious activity, not just who owns or hosts the platform.

- Can the responsible institution inspect logs and software changes?
- Can it revoke a compromised supplier's access?
- Can it direct containment without waiting for consent from a foreign provider?

Control exists only when those powers can be exercised and tested. Resilience must be designed for imperfect conditions: degraded networks, unavailable vendors, compromised credentials, and uncertainty about an incident's source. Emergency procedures, backups and manual citizen-service channels need owners, exercises and funding before an attack — not after one has interrupted access to money or essential entitlements.

- 1 Detect before disruption.** Monitor identity, API, administrative and supply-chain signals even while services appear healthy.
- 2 Own the response.** Define who can isolate a component, revoke access, and communicate with affected institutions.
- 3 Prove continuity.** Exercise essential transactions and citizen-facing fallback channels under realistic loss of service.
- 4 Treat quiet periods as exposure windows.** Use continuous testing and threat-informed review rather than waiting for a public incident.

The governing principle

The absence of visible failure cannot define security. Security is the system's demonstrated ability to withstand and operate under active threat conditions — verified, not assumed from the fact that nothing has visibly gone wrong yet.

2. AI has become the attacker force multiplier

AI compresses the time between reconnaissance, targeting, exploitation and adaptation. It helps attackers generate convincing social engineering, analyse exposed code, chain vulnerabilities, automate discovery, and use legitimate tools in ways that evade traditional malware-focused detection. As a result, the DPI defence model cannot rely on slow manual response cycles or perimeter thinking.

AI also expands the DPI attack surface because AI is increasingly part of the DPI stack itself. Fraud detection, biometric liveness checks, social protection eligibility, transaction monitoring and automated risk scoring can all introduce model-level risks, including adversarial inputs, data poisoning, model inversion, biased outcomes and compromised model supply chains.

The security challenge is not confined to malicious code written by AI. Attackers can impersonate support staff, exploit excessive API permissions, search disclosed configuration for useful pathways, and adjust their methods after each defensive action. A DPI programme that reviews access quarterly but changes integrations daily creates a widening gap between the pace of exposure and the pace of control.

AI-enabled services also deserve their own threat model. A fraud score may delay a payment; a liveness tool may deny an identity match; an eligibility recommendation may turn into a de facto benefit

decision. Manipulated inputs, unreviewed model updates or misleading automated outputs can therefore harm people without bringing the platform down. Security assessment must be paired with data minimisation, human review and meaningful recourse.

For the Foundation's security, safety and rights lens, the test is whether controls work when the model is wrong or an authorised user is deceived. Restrict what agents and applications can ask of registries; record why information was accessed; return only the evidence needed for the decision; and make disputed outcomes traceable to an accountable human institution.

- 1 **Constrain access.** Give AI services and agents the narrowest data and action permissions needed.
- 2 **Test model abuse.** Include adversarial inputs, poisoned data, compromised dependencies, and harmful decision outcomes.
- 3 **Keep decisions contestable.** Log material AI influence and provide workable human review and correction.
- 4 **Accelerate the defence.** Link timely telemetry, triage, patching and response to the pace of change.

3. DPI is now critical national infrastructure

Identity platforms, payment rails, health data systems, welfare delivery channels and government data exchanges are no longer convenience systems. They are systems through which citizens prove who they are, receive money, access services and interact with the state. That makes them attractive targets for criminal groups, geopolitical adversaries, and actors seeking to erode public confidence.

The practical implication is that DPI security should be funded, governed and assured as critical national infrastructure. This includes independent penetration testing, secure software development controls, incident response exercises, recovery planning, privileged access monitoring, supply chain assurance, and clear accountability for risk-acceptance decisions.

A single weakness may travel across public services because interoperable systems are connected by design. An identity assertion may unlock a welfare payment; a payment instruction may depend on a beneficiary registry; and a data exchange may pass sensitive information among agencies. This makes the practical security boundary larger than any ministry, system integrator or platform owner. Assurance must examine the transactions and their dependencies.

Critical-infrastructure treatment also changes the funding question. Security cannot sit in a one-off implementation budget while the connected population and the number of integrations continue growing. Governments and funders need to provide for secure maintenance, software bill of materials visibility, vulnerability disclosure, exercises, replacement of ageing dependencies and independent testing throughout the service life.

The objective is not to militarise ordinary service delivery or make inclusion secondary to security. It is to protect continuity and rights together: rapid containment without arbitrary exclusion, incident disclosure without unnecessary exposure of personal data, and recovery plans that keep essential services reachable through assisted or offline channels where possible.

- 1 **Protect the whole service chain.** Map dependencies across identity, payments, registries, and data exchange.

- 2 **Assure independently.** Test security beyond the claims of those who build, host or operate the system.
- 3 **Fund the operating life.** Budget for monitoring, patching, red-team exercises, maintenance and recovery.
- 4 **Protect the citizen.** Maintain privacy, access, appeal, and continuity during incident response.

4. Attrition and the Global South exposure gap

Cyberwar often works through attrition rather than dramatic confrontation. Each apparently minor incident gives attackers more knowledge of the environment, more insight into institutional behaviour, and more opportunity to identify the moment when exploitation will have maximum impact.

The Global South faces a difficult asymmetry. Many countries are moving quickly to adopt and scale DPI because the development benefits are real. Yet the security institutions, specialist workforce, funding levels and national incident response capabilities required to protect those systems often lag behind the speed of deployment. This reverses the ideal sequence: population-scale dependency grows faster than population-scale defence.

Closing this gap does not require every country to build a large national cyber command before digitising services. It does require honest risk recognition, regional cooperation, minimum security baselines, independent assurance, and a commitment to treat security as an operating function rather than a project close-out item.

Attrition is particularly difficult to manage where a small national team oversees several essential platforms, multiple delivery partners, and an expanding number of local integrations. A seemingly minor credential leak, delayed security patch or recurring API misconfiguration can become one more piece of an adversary's understanding of the national environment. Weaknesses accumulate even when no single event looks like a crisis.

Capacity constraints should not be confused with lack of commitment. Countries may face legitimate pressure to extend benefits, payments and identity services quickly while specialist staff and maintenance resources remain scarce. The answer is to make shared security capacity part of the development model: agreed minimum controls, trained local teams, trusted regional support, coordinated vulnerability disclosure and reusable assurance methods across Digital Public Goods.

The Foundation's public-interest approach also asks who carries the cost when defences lag. Citizens dependent on a grant, a clinic, a payment wallet or a digital credential should not become the shock absorber for weak institutional planning. Funders and governments can reduce that risk by financing safeguards, civil-society feedback, recovery capability and accessible recourse as enduring services — not optional extras at programme close-out.

- 1 **Start with a defensible baseline.** Name accountable operators, map dependencies and prioritise critical exposures.
- 2 **Pool scarce capabilities.** Use regional expertise and shared DPG security services without surrendering national accountability.
- 3 **Make funding continuous.** Protect security and recovery budgets beyond the initial deployment milestone.

- 4 Measure real-world harm.** Track exclusion, interruption, fraud and failures of remedy alongside technical incidents.

What this means for a country running DPI

A national identity, payment or data exchange platform does not operate in peacetime conditions merely because the country itself is at peace. It operates inside an active, contested digital threat environment from the day it goes live.

Treating DPI security as a one-time deployment milestone rather than a continuous, funded, institutional discipline is the single most consequential strategic error a country can make in this domain.

Series bridge

The next article turns this threat analysis into an implementation question: how can security, rights and sovereignty be designed into Digital Public Infrastructure at the architecture stage rather than attached after launch? It moves from why control matters under pressure to the governance, trust, data, platform, operations and ecosystem decisions that make control verifiable.

About the author

Godfrey Kutumela (He/Him)

CISSP (MSc Information Security), CCSP, CSSLP, TOGAF, ISO 27001 LA, MDP

Executive Lead and Digital Trust Practitioner, Digital Trust Futures Foundation

Godfrey Kutumela is a globally recognised cybersecurity practitioner with over 26 years of experience shaping secure digital ecosystems across fintech, identity and public infrastructure environments. He operates at the intersection of Digital Public Infrastructure (DPI), Digital Public Goods (DPGs) and national-scale platforms, bringing deep expertise in securing systems where the impact of failure is measured at the population level rather than the enterprise level.

- Trusted advisor to governments, foundations and ecosystem builders delivering secure-by-design DPI across Africa, Latin America and global markets.
- Core contributor to large-scale platforms including Mowali (mobile money interoperability infrastructure), Mojaloop (interoperable faster payments), MOSIP (digital identity) and Tazama (fraud systems).
- Designs and embeds independent, risk-based security practices across payment systems, identity frameworks and cross-border financial infrastructure.
- Works across policy, architecture and implementation layers, translating global standards into deployable security controls.
- Contributor to the Digital Public Goods Alliance (DPGA) Privacy Expert Group, shaping global privacy and security indicators.
- Active in open-source security, DevSecOps integration and supply chain assurance for reusable digital platforms.

- Delivered independent security reviews, penetration testing and architecture governance across critical DPI implementations.

His leadership philosophy in the DPI ecosystem is clear: security forms the foundation upon which safety and trust are built. Safety is what citizens experience in practice, and trust is the legitimacy that sustains adoption; once lost, it is difficult to restore.

About Digital Trust Futures Foundation

Digital Trust Futures Foundation is an independent, non-profit public-benefit organisation strengthening the safety, security, rights, inclusion and trustworthiness of digital public infrastructure (DPI), digital public goods (DPGs), open-source technology and AI-enabled public services. Its work is grounded in the recognition that DPI has become critical national infrastructure operating in a persistent threat environment, requiring independent, ecosystem-level assurance that goes beyond traditional approaches.

The Foundation operates outside vendor, implementer and platform incentives. It combines evidence-based cybersecurity, safety and AI-governance assurance with human-rights and child-protection expertise, and releases its tools, research and frameworks as reusable public goods rather than proprietary products — so that the value of a single engagement extends to every government, maintainer and community facing the same risk.

Digital Trust Futures Foundation NPC is registered as a non-profit company in South Africa and works across Africa and the wider Global South, with emphasis on countries and communities adopting DPI under capacity and assurance constraints.

Digital Trust Futures Foundation | Safe infrastructure. Trusted technology. Inclusive digital futures.
info@digitaltrustfuturesfoundation.org | digitaltrustfuturesfoundation.org | +27 83 680 3427

Published as a public good. This paper may be shared and quoted with attribution to Digital Trust Futures Foundation NPC. It is provided for general information and does not constitute a certification, assurance opinion or endorsement of any system, product or jurisdiction.

References and further reading

This list is organised by institutional category to help readers navigate quickly to the type of source most relevant to their work. It reflects the regulatory and threat landscape as understood at the time of writing, and should be revisited periodically: several of the instruments listed remain subject to active negotiation and change.

United Nations and UN agencies

- UN Office for Digital and Emerging Technologies (ODET) — Universal DPI Safeguards Framework and DPI Safeguards Resource Hub, co-led with UNDP.
- UN Development Programme (UNDP) — Digital Public Infrastructure guidance and co-stewardship of the Digital Public Goods Alliance.

- UN General Assembly — Global Digital Compact (2024) and associated digital cooperation follow-up processes.
- International Telecommunication Union (ITU) — GovStack Initiative (with GIZ, Estonia and UNDP), reusable government Building Block specifications.
- UN Conference on Trade and Development (UNCTAD) — Digital Economy Report series, covering cross-border data flows and data sovereignty for developing economies.
- World Bank Group — Identification for Development (ID4D) Practitioner's Guide and Principles on Identification for Sustainable Development.
- World Bank — "Resilient, Secure and Trusted: The Next Frontier for Digital Public Infrastructure" (2025).
- World Economic Forum — "Building Security into India's Digital Public Infrastructure" (October 2025) and DPI security risk taxonomy.
- OECD — Going Digital project and DPI security and governance guidance, including modular and federated architecture recommendations.

European Union, ENISA and European bodies

- European Union — General Data Protection Regulation (GDPR), Regulation (EU) 2016/679, including Chapter V cross-border transfer rules and Article 48.
- European Union — Cloud and AI Development Act (CADA), proposed 3 June 2026 as part of the European Technological Sovereignty Package.
- European Union — EU AI Act, in force August 2024; classifies AI used in biometric identification, social benefits determination and essential-services access as high risk.
- European Union — Digital Services Act (DSA) and Digital Markets Act (DMA), platform governance and gatekeeper obligations.
- European Union — Network and Information Security Directive 2 (NIS2), critical-infrastructure cybersecurity obligations across Member States.
- European Union Agency for Cybersecurity (ENISA) — cybersecurity guidance, threat landscape reporting and technical input to the EU Cybersecurity Certification Scheme for Cloud Services (EUCS).
- Court of Justice of the European Union — Schrems II (Case C-311/18, 2020), invalidating the EU-US Privacy Shield.
- European Data Protection Board — Recommendations 01/2020 on supplementary measures for cross-border data transfers.
- European Commission — European Technological Sovereignty Package (3 June 2026), including the EU Open Source Strategy and Chips Act 2.0.
- European Commission, DG CONNECT — Cloud Sovereignty Framework and "Shaping Europe's Digital Future" portal.

United States: statutes, authorities and agencies

- Clarifying Lawful Overseas Use of Data Act (CLOUD Act), 2018 — establishes provider "possession, custody, or control", not data location, as the trigger for compelled disclosure.

- Foreign Intelligence Surveillance Act (FISA) Section 702 — authorises US agencies to direct US-based providers to disclose communications of non-US persons abroad.
- Executive Order 12333 (1981, as amended) — foundational authority for US signals intelligence collection outside the United States.
- USA PATRIOT Act Section 215 — authority for compelled production of “tangible things” relevant to foreign intelligence investigations.
- United States v. Microsoft Corp. (2018) — the Dublin email-disclosure dispute that the CLOUD Act rendered moot.
- US National Institute of Standards and Technology (NIST) — Digital Identity Guidelines (SP 800-63-4); Secure Software Development Framework (SP 800-218); Cybersecurity Framework; AI Risk Management Framework.
- US Cybersecurity and Infrastructure Security Agency (CISA) — advisories, Known Exploited Vulnerabilities catalogue and critical-infrastructure guidance.
- US National Trade Estimate Report on Foreign Trade Barriers, 2026 edition — trade-policy treatment of foreign data localisation and sovereign cloud measures.

Other national and regional regimes

- China — Cybersecurity Law (2017), Data Security Law (2021), Personal Information Protection Law (2021), and Article 7 of the National Intelligence Law (2017).
- Russian Federation — Federal Law No. 152-FZ “On Personal Data”, requiring localisation of citizens’ personal data on servers within Russia.
- India — Digital Personal Data Protection Act (2023) and the Data Empowerment and Protection Architecture / Account Aggregator consent framework.
- Brazil — Lei Geral de Proteção de Dados Pessoais (LGPD), with extraterritorial effect and an independent supervisory authority.
- Estonia — Data Embassy concept and bilateral treaty with Luxembourg, extending Estonian jurisdiction to offshore infrastructure.
- Canada — Foreign Extraterritorial Measures Act and the emerging Canadian Sovereign Cloud Initiative.
- African Union — Digital Transformation Strategy for Africa (2020–2030) and the AfCFTA e-commerce protocol.
- Association of Southeast Asian Nations — ASEAN Digital Masterplan 2025.

Cloud and technology providers

- Microsoft — Azure sovereign cloud documentation: EU Data Boundary, Managed HSM external key storage, confidential computing.
- Google Cloud — Cloud External Key Manager and Cloud Key Management Service documentation on customer-managed and customer-held keys.
- Amazon Web Services — Key Management Service, Nitro Enclaves for confidential computing, and the AWS Digital Sovereignty Pledge.
- Thales CipherTrust — guidance on Bring Your Own Key, Hold Your Own Key and external key management for cloud data sovereignty.

- Utimaco — Enterprise Secure Key Manager, general-purpose HSMs and double key encryption reference architectures.
- Open Source Security Foundation / Linux Foundation — OpenSSF Scorecard and Supply-chain Levels for Software Artifacts (SLSA).

DPI and DPG frameworks and communities

- Digital Public Goods Alliance — DPG Registry, DPG Standard and the 50-in-5 campaign.
- MOSIP Foundation / IIIT-Bangalore — security architecture documentation for digital identity digital public goods.
- Mojaloop Foundation — security model and architecture for interoperable instant payment infrastructure.
- Estonia X-Road / Nordic Institute for Interoperability Solutions — secure government data exchange reference architecture.
- Centre for Digital Public Infrastructure / IIIT-Bangalore — DPI architecture and governance guidance, including G2P Connect specifications.
- Co-Develop Fund and the Global DPI Summit — country DPI journey funding and convening.
- Bill & Melinda Gates Foundation — Digital Public Infrastructure programme funding MOSIP, Mojaloop, DHIS2 and the Upanzi Network.
- Digital Impact Alliance — Principles for Digital Development.

Threat intelligence, standards and technical references

- CrowdStrike — 2026 Global Threat Report (Counter Adversary Operations).
- MITRE ATT&CK Framework — knowledge base of adversary tactics, techniques and procedures for nation-state threat modelling.
- OWASP Foundation — OWASP API Security Top 10.
- Center for Internet Security — CIS Benchmarks for cloud infrastructure and operating system hardening.
- ISO/IEC — ISO/IEC 27001 (Information Security Management) and ISO/IEC 42001 (AI Management Systems).
- Center for Strategic and International Studies — Significant Cyber Incidents Tracker and "Approaches to Digital Public Infrastructure in the Global South".
- IBM — Cost of a Data Breach Report (2024 edition, regional analysis).
- Thomas Murray — GCC Regional Risk Update series (2026).
- Dubai Electronic Security Center — Dubai Cyber Security Strategy, cited as a reference model for institutionalised cyber governance.